



SCHOOL HOMEWORK - 2023

CLASS : APPLICATION SECURITY

SUBJECT: ATTACK TREE, DATABASES & MASKS, CERTIFICATES &
ENCRYPTION, MANAGEMENT WITH SQL MANAGEMENT STUDIO

FRÉDÉRIC PERRON

Table of Contents

Q1 – Attack Tree 1

Q2 – Data Classification 2

Q3 – Roles 6

Q4 – Masks 9

Q5 – Certificates and encryption 11

Q6 – Backup Script..... 14

Q7 – Enable auditing on the insertion or modification of ProductReview.. 17

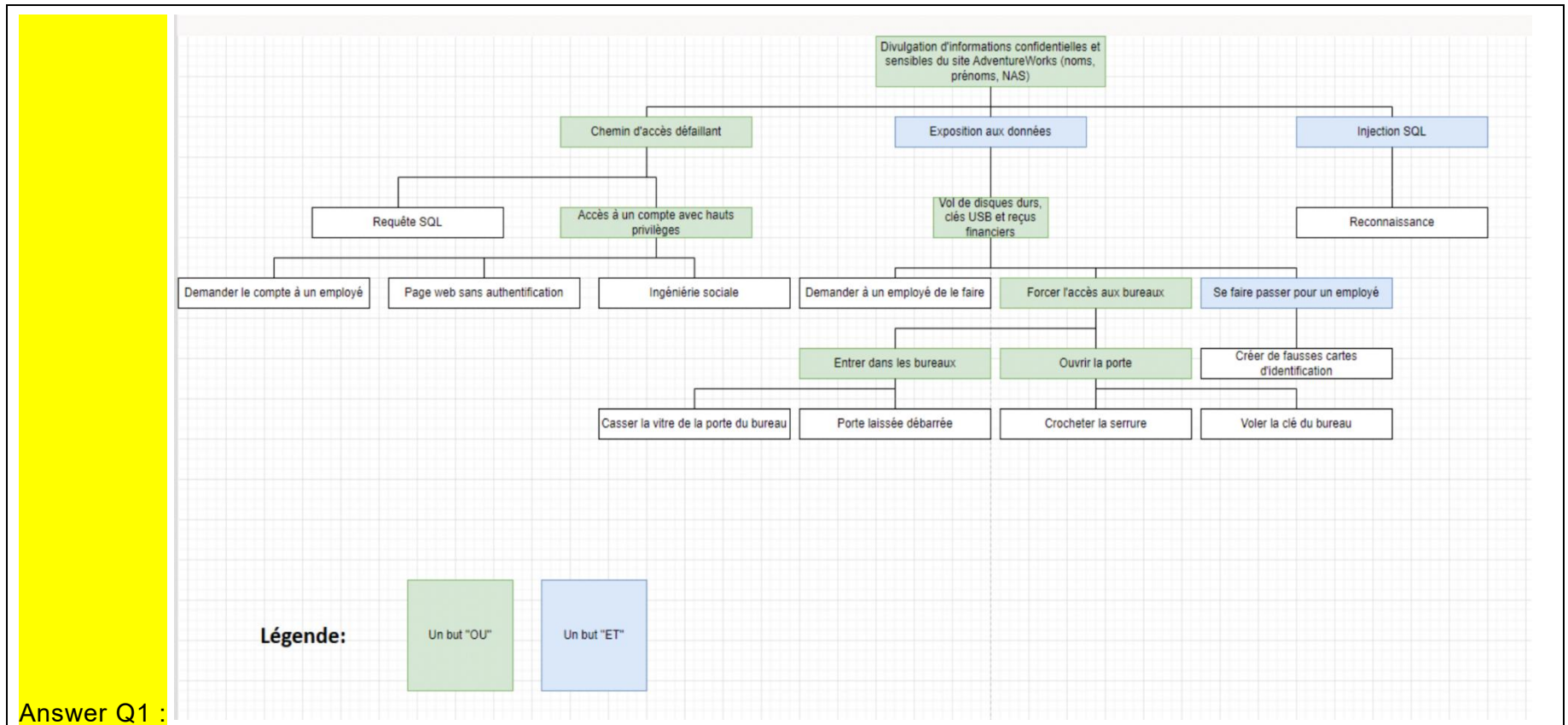
Q8 – Advices for the client 18

Q (bonus) – Add a user and a role for this new site. Adjust their permissions. 19

Q1 – Attack Tree

Create an attack tree for "Retrieving employees' first name, last name, and social insurance number from the database," knowing that the database is linked to a web-based ERP (Customer Relationship Management) system.

(Take inspiration from the information given when we studied information disclosure vulnerabilities.)

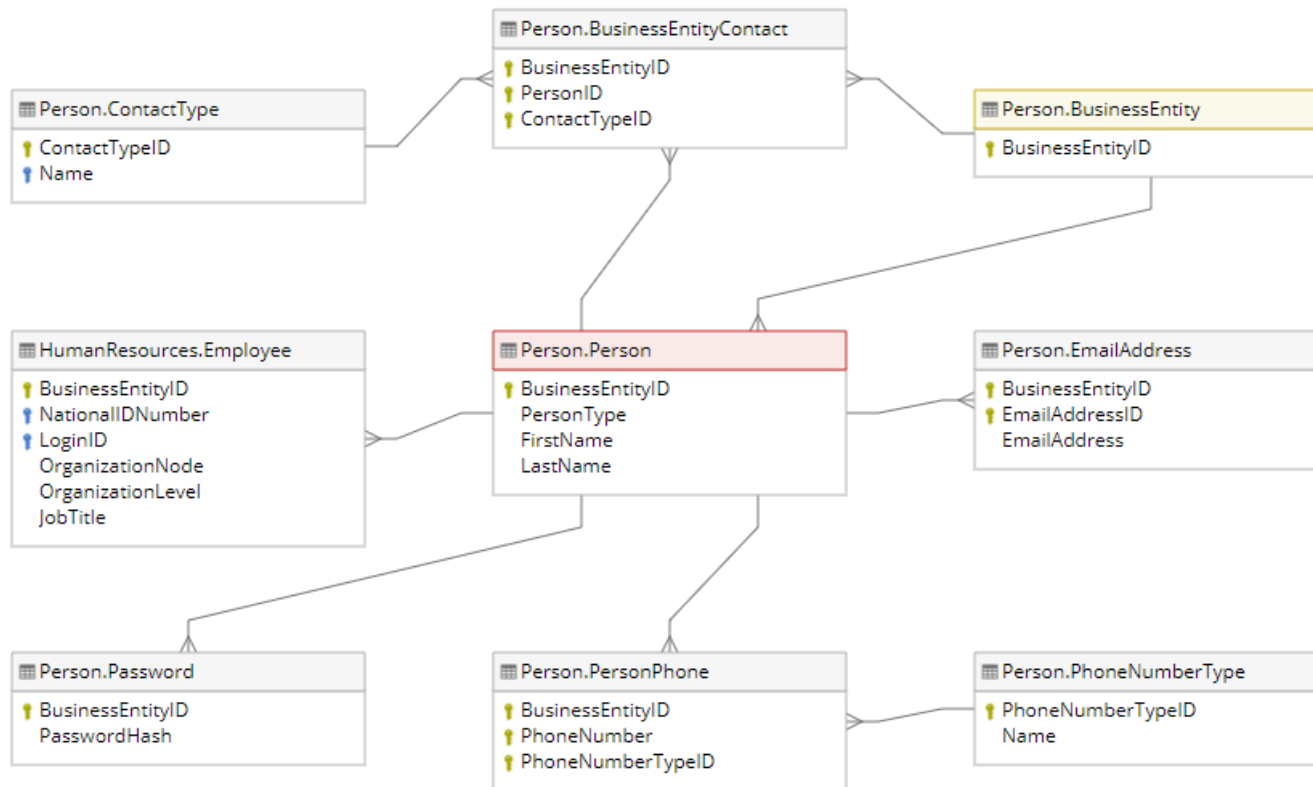


Answer Q1 :

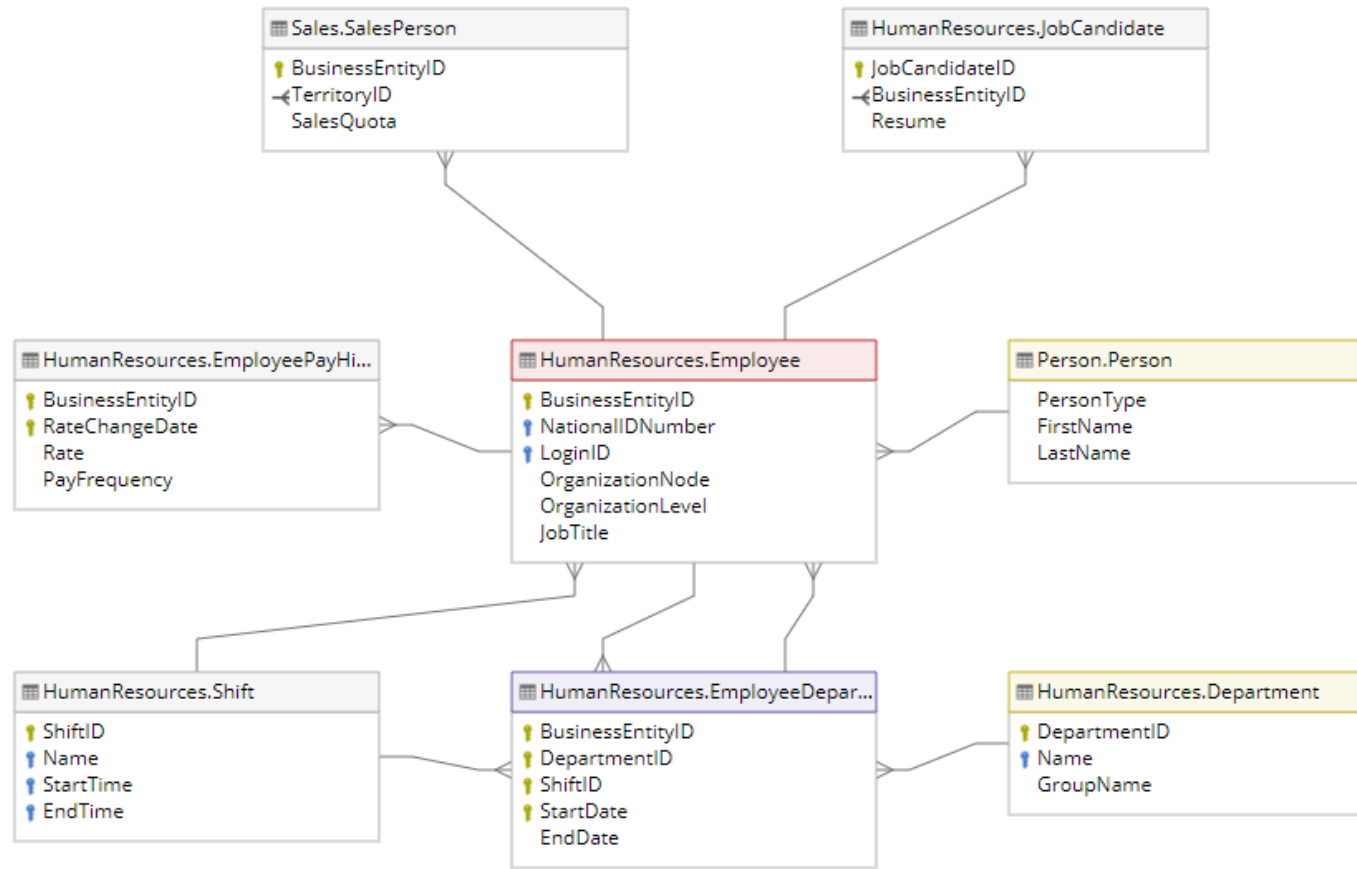
Q2 – Data Classification

Export your updated SQL Data Classification Report based on your analysis. Attach it using this response template. You only need to classify the data shown under the following diagrams:

People



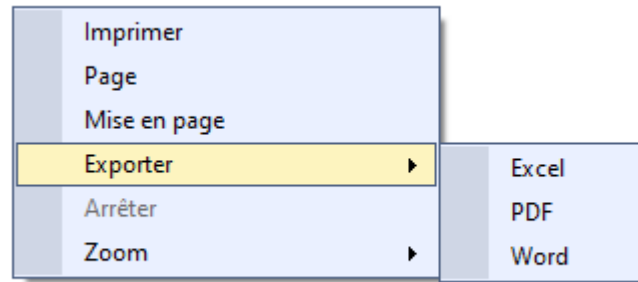
Human Resources



Production.ProductReview	
ProductReviewID	int
ProductID	int
ReviewerName	nvarchar(50)
ReviewDate	datetime
EmailAddress	nvarchar(50)
Rating	int
Comments	nvarchar(3850)

Answer Q2 :

Put this in a separate file. Use Export > Word. Include it with this response template.



Name of the file: Data Classification – 2022-11-29 224 AM - FREDMAINPC *see image below*

SQL Data Classification Report



Server name: FREDSMAINPC
Database name: AdventureWorks2019

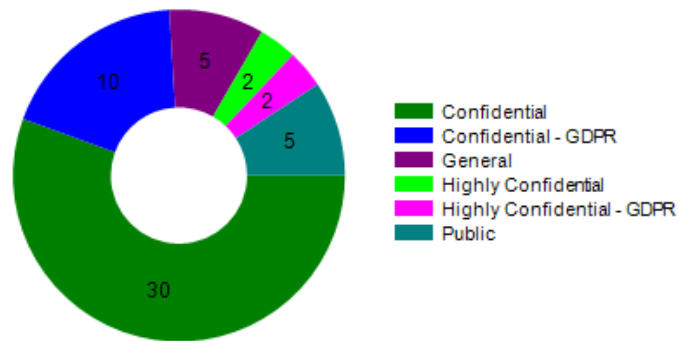
Report generated on: 2022-12-01 10:00:23 AM

Classified columns
54 / 486

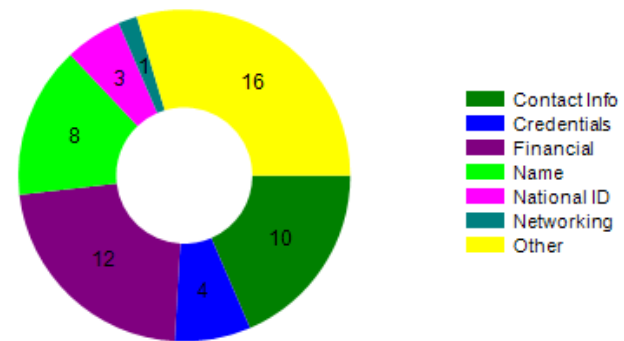
Tables containing sensitive data
16 / 71

Unique information types
7

Label distribution



Information Type distribution



Schema	Table	Column	Information Type	Sensitivity Label
HumanResources	EmployeePayHistory	BusinessEntityID	Financial	Confidential
Person	Password	BusinessEntityID	Credentials	Highly Confidential
Production	ProductReview	Comments	Other	Public
Sales	SalesPerson	BusinessEntityID	Financial	Confidential

Q3 – Roles

Create roles relevant to the context. Provide an example of how you added one role.

(Reference: <https://docs.microsoft.com/en-us/sql/relational-databases/security/permissions-database-engine?view=sql-server-ver15>)

Answer Q3 :

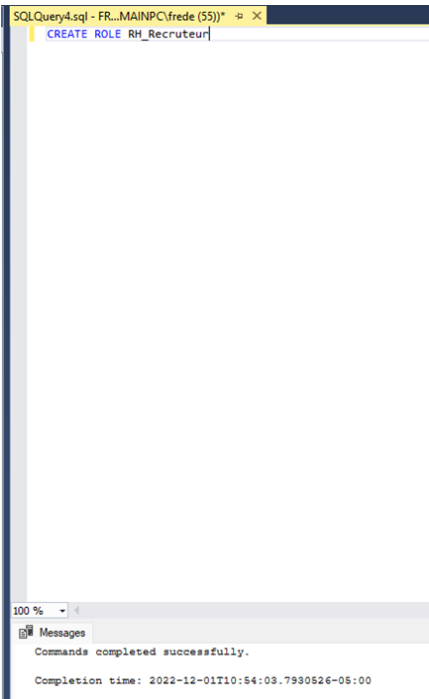
Only for the tables that will be used by Human Resources, create a table of the roles you would implement.

Hints for consideration: *keep in mind that the Human Resources department has a recruitment service, a payroll service, an administrative service, and a tax service—which only sends tax accounts at the end of the calendar year during tax updates.*

Rôle	Table	Description des permissions	Détails
RH_Recruteur	JobCandidate	Create, Edit, Insert	The recruiter can only edit and create in the database the information related to candidates.
RH_Fiscal	EmployeePayHistory	Read	Has read-only access to tax data, only to send it at the end of the calendar year.
RH_AdminManager	Toutes les tables de HumanResources <i>All tables of HumanResources</i>	Create, Delete, Edit, Read, Insert, Alter, etc.	Administrative permission on the entire instance. This role should be assigned to the head of Human Resources.
RH_PayrollManager	EmployeePayHistory	Read, Edit, Insert, Delete	The payroll manager handles everything related to payroll (errors, pay rate changes, etc.). They can read, edit, insert, and delete in the EmployeePayHistory table.

Example of the script or procedure (show that you have tested it) :

1- We have added a role of recruiter for the HR. See image below :

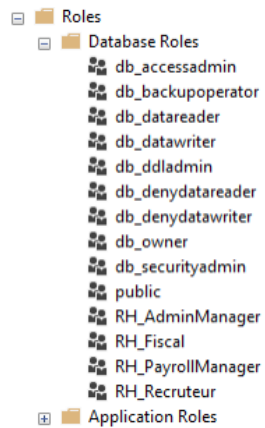


- 2- Here is a screenshot that also demonstrates the read or “view” permission for the role RH_Fiscal:
The same was done for each role and their permissions given in the table above

```
SQLQuery6.sql - FR...MAINPC\frede (32)*  
GRANT create view TO RH_Fiscal
```

100 %
Messages
Command completed successfully.
Completion time: 2022-12-01T12:32:40.3867442-05:00

3- And finally, here is a screenshot that clearly shows our 4 roles added to the database :



Q4 – Masks

Choose 3 columns suitable for masking. Prioritize confidential data.

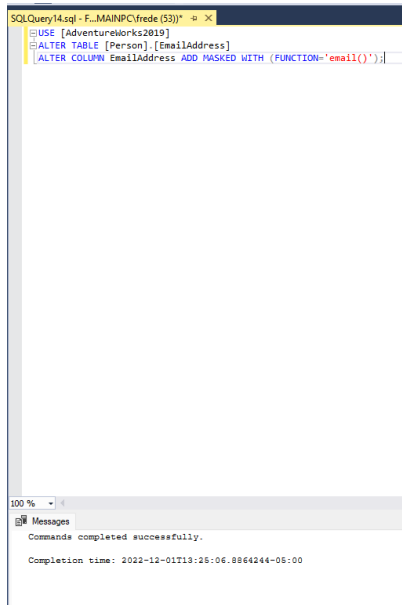
You cannot use NationalIdNumber or CreditCardNumber.

Perform a SELECT on each mask you have implemented with one role that has access and another role that does not. Paste screenshots for each (query + results) here:

Email addresses were masked simply using the DEFAULT function, as well as employees' LoginID and their pay rates. See images of the commands used below:

Answer Q4 :

1- We used the following command to mask email addresses with the email function:



```
SQL Query14.sql - F:\MAINPC\Frede (33)*
USE [AdventureWorks2019]
ALTER TABLE [Person].[EmailAddress]
ALTER COLUMN EmailAddress ADD MASKED WITH (FUNCTION='email()')
```

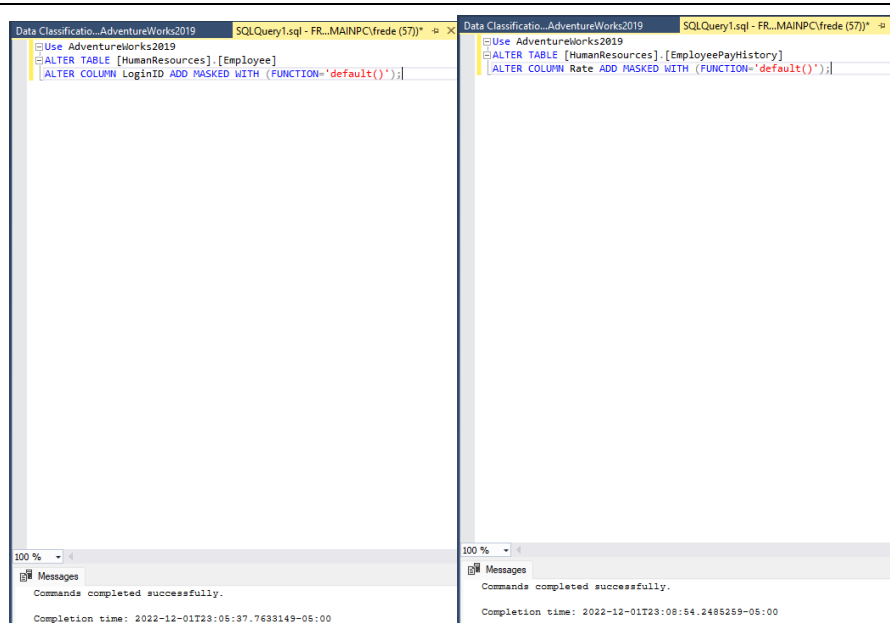
100 %

Messages

Commands completed successfully.

Completion time: 2022-12-01T13:26:06.8864244-05:00

2- Here are the screenshots that also demonstrate the masking of employees' LoginIDs and pay rates:



3- Here is now the HR_AdminManager role with permission to view the masked data:

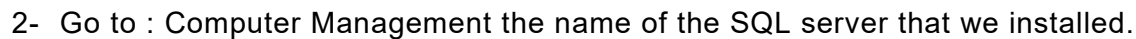


The other default roles do not have access to the masked data.

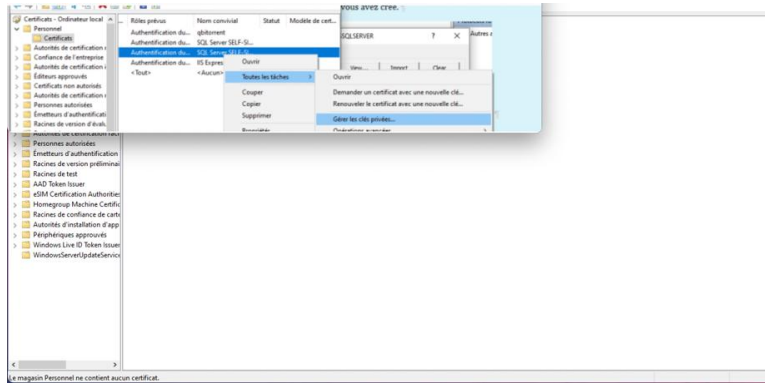
Take screenshots of the commands and the results of your commands and/or the SSMS window.

- Answer Q5 :

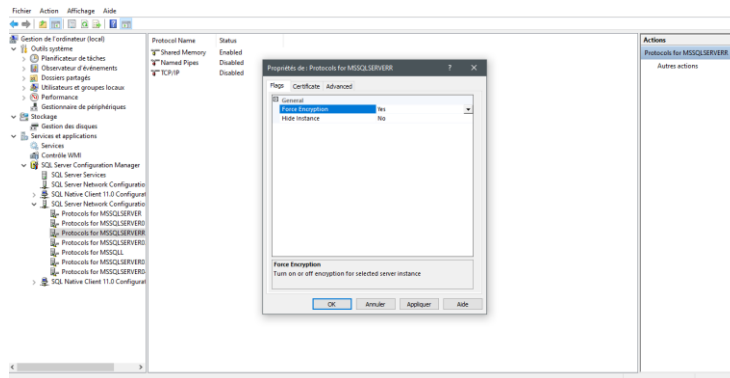
1- Create our own **TLS** certificate.



3- We went to: Certificate Management to enable the certificate we installed in order to apply it to SQL.

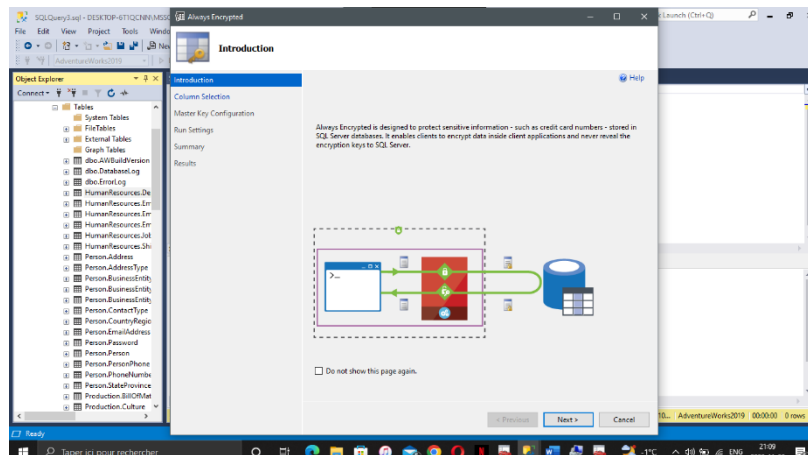


4- We forced encryption on the SQL Server by selecting the certificate we created.



Pour **Always Encrypted** la colone HumanResources.Employee.NationalIDNumber on a :

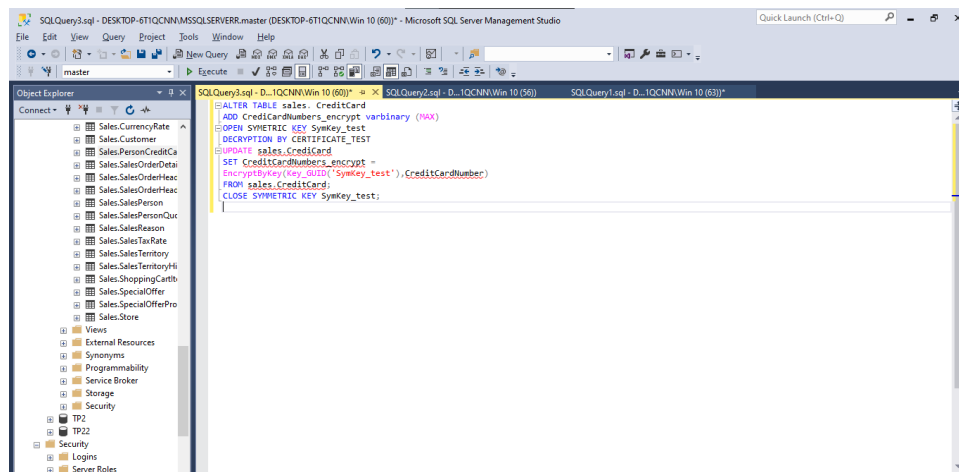
- 1- Cliquer sur graphe Tables
- 2- Clic droit sur la colonne concerné – Encrypt Columns, ensuite nous avons suivi les étapes de configuration



To manually encrypt **Sales.CreditCard.CreditCardNumber**, we :

- 1- Thanks to the certificate we created, we were able to encrypt the sales.CreditCard.CreditCardNumber column by entering the following commands in SQL :

```
ALTER TABLE sales. CreditCard
ADD CrediCardNumbers_encrypt varbinary (MAX)
OPEN SYMETRIC KEY SymKey_test
DECRYPTION BY CERTIFICATE_TEST
UPDATE sales.CrediCard
SET CreditCardNumbers_encrypt =
EncryptByKey(Key_GUID('SymKey_test'),CreditCardNumber)
FROM sales.CreditCard;
CLOSE SYMMETRIC KEY SymKey_test;
```



2- Delete the old column and we rename the one that we just added.

Q6 – Backup Script

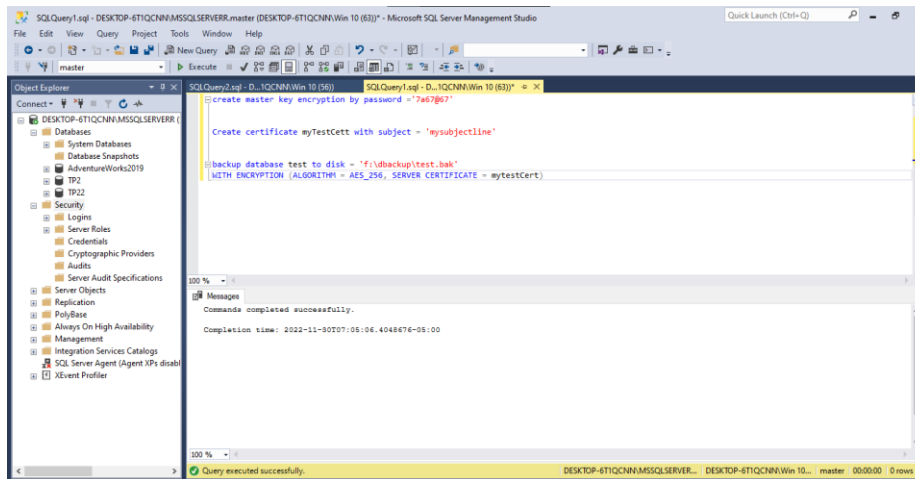
Set up daily encrypted backups.
Include a screenshot of this configuration.

Answer Q6 :

Step 1: We backed up the certificate we created using the following command.

Backup certificate myTestCert to file = 'f:\dbbackup\test.bakcup\Test_db_certificate.cert'

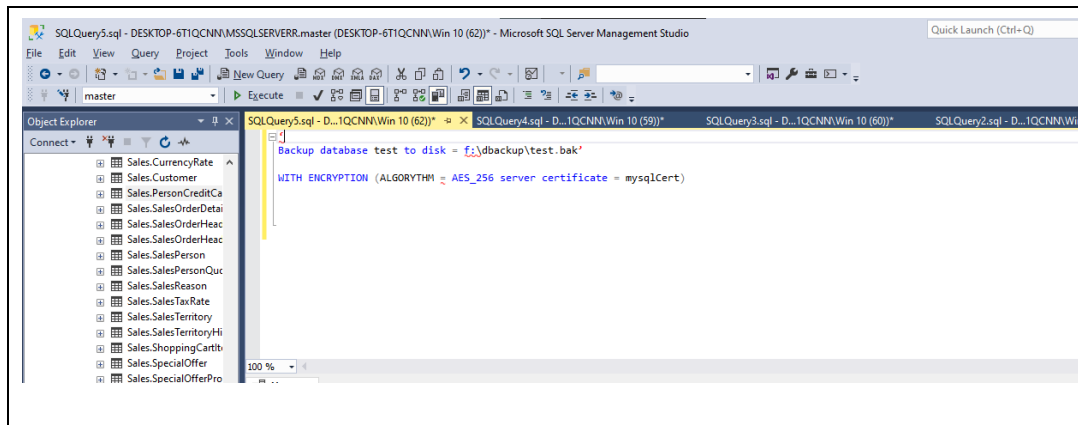
With private key (file = 'f:\dbbackup\test.bakcup\Test_dbkey.key', encryption by password : 12345sql)



Step 2: Then we entered the following commands to back up the database.

Backup database test to disk = f:\dbbackup\test.bak'

WITH ENCRYPTION (ALGORITHM = AES_256 server certificate = mysqlCert)

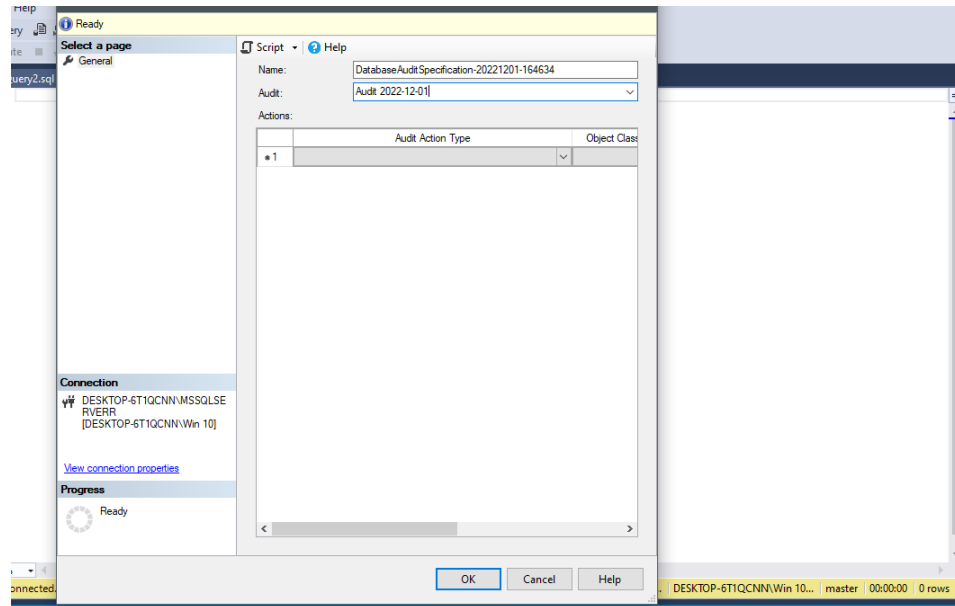


Q7 – Enable auditing on the insertion or modification of ProductReview..

Copy and paste your script below:

Answer Q7 :

1. Right-click on Audit → *New Audit* → *New Audit Database Specification*



2. Show the audit :

```
SELECT * FROM sys.fn_get_audit_file ('C:\tmp\AuditMotDePasse_C51805EE-DFEB-4F48- AA11-50206988DDC9_0_132812358377770000.sqlaudit',de fault,default);
```

Q8 – Advices for the client

Give your recommendations to your client who is putting this database into operation.

Are there any security suggestions you could implement to secure the application? Keep in mind the client doesn't know much about IT and even less about security.

Answer Q8 :

Advices

- Encrypt all sensitive columns to prevent sensitive information from being accessed by unauthorized persons. Use Always Encrypted for data at rest and in transit (Microsoft SQL Server).
- Implement Row-Level Security (RLS) so that database users can only access data related to their role/function (Microsoft SQL Server).
- Enable auditing at the server level and allow database-level auditing to inherit the server-level audit settings for all databases.
- Ensure strong authentication for users according to their roles, and make sure to keep a user log audit trail (Microsoft SQL Server).
- Security practice based on the principle of least privilege.
- Choose Active Directory authentication instead of SQL authentication.
- Require strong passwords and implement multi-factor authentication.
- Reduce the rights granted to the Admin account and ensure that system administrator accounts are removed after their use.
- It is recommended to enable only the features required by your environment in order to reduce the number of features that could be attacked.
- Perform regular vulnerability assessments.
- Backup the master key and store it securely in a vault
- Back up the data and store it on a different system than the database to be able to restore it in case of data loss, and ensure these backups are encrypted.
- Store only the necessary information.
- Use hashing functions
- Be cautious of code injection attacks, which are common with databases, by monitoring automatic input from applications, ensuring full server protection, and hardening the database using strong code (Inos.fr).

Q (bonus) – Add a user and a role for this new site. Adjust their permissions.

Copy paste your scripts below :

Answer Q10.2 : We are going to add an ITmanager role, so it would have almost all permissions.

To add a new user:

We go in Security → User → New User → We enter username and password → Enter the SQL server which it has access

Scripts:

```
CREATE LOGIN steve_ITmanager  
WITH PASSWORD = 'A$bXj5Hw9gW6uO',  
CHECK_POLICY = ON;
```

GO

To create a custom role:

```
CREATE ROLE site_ITmanager;
```

GO

Permissions attribution:

```
GRANT SELECT, INSERT, UPDATE, DELETE  
ON SCHEMA::dbo  
TO site_ITmanager;
```

GO

Schema object management:

```
GRANT EXECUTE  
ON SCHEMA::dbo  
TO site_ITmanager;
```

GO

Add a user to the role:

```
ALTER ROLE site_ITmanager  
ADD MEMBER steve_ITmanager;
```

GO

References :

<https://www.ionos.fr/digitalguide/serveur/securite/injection-sql-bases-et-mesures-pour-se-proteger/>

[How to Encrypt a Database Backup in SQL server || Backup Encryption || Ms SQL](#)

<https://learn.microsoft.com/fr-fr/sql/relational-databases/security/sql-server-security-best-practices?view=sql-server-ver16>